

CWE AI Working Group: Modification Subgroup

September 12, 2025

Attendance

Steve Christey Coley

Martin Hodo

Carolina Rocha

Erick Galinkin

Monika Akbar

Bamidele Ajayi

Mirzah Ali

Agenda

- Status Updates
- CWE Release Information
- Work Planning

Meeting Notes:

Status Updates

Steve welcomed everyone to the meeting and introduced Bamidele Ajayi, a new member who works with M Service Now as a security engineer focusing on AI risk.

Steve introduced Bamidele Ajayi, who works with M Service Now as a security engineer focusing on AI risk. Bamidele is also completing a PhD in computer science with a focus on AI and security.

Steve provided an update on the recent CWE 4.18 release, available as of September 9th, highlighting the inclusion of AI-related changes and the new entry for insecure hyperparameters. He thanked the team for their hard work and discussed the challenges and considerations involved in the release.

- **Challenges:** Steve discussed the challenges faced in capturing the consequences of exploiting the weakness, such as inaccurate or misleading information and propagating errors to other systems, especially in critical decision-making processes.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

- **Technical Impact:** Steve explained the limited set of values within CWE for technical impact, which are intended to apply to various software and hardware types, and mentioned the potential for domain-specific improvements in future releases.
- **Future Plans:** Steve mentioned the goal of expanding or improving domain-specific terminology in CWE 5.0, which is planned for a future release, but noted that the upcoming release in a couple of months will be CWE 4.19 with no major changes.

CWE Release Information

Steve explained the relationships and classifications of CWE-1434: Insecure Setting of AI/ML Model Inference Parameters, discussing the challenges of capturing consequences and the potential for multiple parent weaknesses. He emphasized the importance of accurate classification and the complexities involved.

- **Classification Challenges:** Steve explained the difficulty in capturing the consequences of exploiting the weakness, such as inaccurate information and errors in critical decision-making processes.
- **Multiple Parents:** Steve discussed the potential for CWE entries to have multiple parent weaknesses due to the various dimensions along which weaknesses can be abstracted, such as behavior, technology, and affected resources.
- **Expected Behavior Violation:** Steve described the primary parent weakness as an expected behavior violation, where the system does not follow the expected behavior, such as performing actions out of order or not fulfilling API contracts.
- **Improper Initialization:** Steve mentioned improper initialization as another parent weakness, where configuring hyperparameters serves as the initialization of the model's behavior.
- **Real-World Data:** Steve noted that the classification work is based on real-world data and past taxonomy work, which can be inconsistent or imperfect, making it challenging to have a single parent for each CWE entry.
- **Demonstrative Example Review:** Steve presented the demonstrative example for CWE-1434, requesting the team's review and feedback to ensure its accuracy and realism. He acknowledged the time constraints and the need for a good example over a perfect one.

- **Example Presentation:** Steve presented the demonstrative example for the new CWE entry, which was built over the last few meetings, and requested the team's review and feedback to ensure its accuracy and realism.
- **Time Constraints:** Steve acknowledged the time constraints and mentioned that he did not have sufficient time to coordinate closely with Eric before publishing the example but emphasized the importance of having a good example over a perfect one.

Work Planning

Steve discussed the growing queue of AI-related submissions and the need for a triage mechanism to prioritize and manage the workflow. Erick suggested preliminary discussions and comments to expedite the process and improve submission maturity.

- **Growing Queue:** Steve highlighted the growing queue of AI-related submissions and the need to prioritize and manage the workflow effectively.
- **Triage Mechanism:** Steve proposed the idea of a triage mechanism to bucket and prioritize submissions, ensuring that high-priority items are addressed promptly.
- **Preliminary Discussions:** Erick suggested having preliminary discussions and comments on submissions to expedite the process and improve the maturity of the submissions before they are formally reviewed.
- **Interim Work:** Steve mentioned the possibility of carrying out work in the CDR or other platforms in the interim between meetings to keep the process moving forward.
- **Consultation Phase:** Steve explained the consultation phase, where Miter interacts with the submitter to clarify the submission and identify any potential issues, and emphasized the importance of this phase in the overall process.
- **Upcoming Meetings and Next Steps:** Steve outlined the upcoming meetings focused on modifications and new entries, and encouraged continued discussions within CDR. He also mentioned his upcoming vacation and the participation of a colleague in the next meeting.
 - **Vacation Notice:** Steve mentioned his upcoming three-week vacation and informed the team

Action Items:

- **New CWE Entry Review:** Review the new CWE entry for insecure hyperparameters and provide feedback on its accuracy and realism. (All participants)
- **Triage Mechanism Experiment:** Experiment with early CDR discussion for triage mechanisms to streamline the review process. (All participants)
- **Labeling Submissions:** Implement a labeling system in GitHub to group submissions relevant to the AI working group for easier navigation. (Steve)
- **Feedback on ANSI Escape Codes:** Continue discussion on the ANSI escape codes in LLM Tokenizers submission within CDR to determine if it should be a new CWE or a modification of CWE-150. (All participants)
- **AI Working Group Involvement:** Discuss and finalize the process for AI working group involvement in CDR discussions to expedite the review and acceptance phases. (All participants)